

APP.4.10 Sicherheit von KI-Systemen

1 Beschreibung

1.1 Einleitung

Systeme der künstlichen Intelligenz (KI) und des maschinellen Lernens (ML) sind integrale Bestandteile von Geschäftsprozessen und kritischen Anwendungen. Sie unterscheiden sich architektonisch von traditioneller Software, da ihr Verhalten nicht explizit programmiert, sondern durch Lernprozesse aus Daten abgeleitet wird. Dieser datenzentrierte Ansatz erzeugt spezifische Angriffsvektoren, die den gesamten Lebenszyklus eines KI-Systems betreffen – von der Erhebung der Trainingsdaten über den Trainingsprozess bis hin zum produktiven Betrieb des gelernten Modells (Inferenz). Die Sicherheit von KI-Systemen umfasst daher den Schutz der Daten, der Algorithmen, der Modelle sowie der ML-Operations-Pipeline (MLOps).

1.2 Zielsetzung

Ziel dieses Bausteins ist es, die spezifischen Risiken im Lebenszyklus von KI- und ML-Systemen systematisch zu adressieren. Es werden Maßnahmen etabliert, um die Vertraulichkeit, Integrität und Verfügbarkeit von KI-Modellen und deren Datenbasis sicherzustellen, die Systeme widerstandsfähiger gegen KI-spezifische Angriffe zu machen und eine sichere Integration in den Informationsverbund zu gewährleisten.

1.3 Abgrenzung und Modellierung

Der Baustein APP.4.10 ist auf alle IT-Systeme und Prozesse anzuwenden, in denen KI- oder ML-Modelle entwickelt, trainiert oder produktiv betrieben werden.

Er behandelt nicht die allgemeinen Sicherheitsanforderungen an die zugrundeliegende IT-Infrastruktur. Diese sind über die entsprechenden Bausteine der Schichten SYS und INF abzusichern. Ebenso wird die generelle Methodik der sicheren Softwareentwicklung in diesem Baustein nicht betrachtet; hierfür ist der Baustein CON.8 *Software-Entwicklung* heranzuziehen. Die allgemeine sichere Speicherung der Trainingsdaten wird durch Bausteine wie SYS.2.1 *Allgemeiner Speicher* oder APP.4.3 *Relationale Datenbanksysteme* ergänzt. Ethische Fragestellungen (z. B. Bias) werden in diesem Baustein nicht primär behandelt.

2 Gefährdungslage

Für den Baustein APP.4.10 sind folgende spezifische Bedrohungen von besonderer Bedeutung:

Datenvergiftung (Data Poisoning)

Angreifer manipulieren die Trainingsdaten, indem sie fehlerhafte, böswillige oder irreführende Daten einschleusen. Dies führt dazu, dass das KI-Modell falsche Muster lernt, systematische Fehler aufweist oder eine „Hintertür“ enthält, die im produktiven Betrieb gezielt ausgenutzt

werden kann.

Gezielte Umgehung und Manipulation von Modellen (Adversarial Evasion)

Angreifer erstellen zur Laufzeit speziell präparierte Eingabedaten, die das KI-Modell zu einer gezielten Fehlentscheidung verleiten. Diese Manipulationen sind für Menschen oft unauffällig, etwa geringfügig veränderte Bildpixel oder subtil angepasste Textbausteine, stören jedoch die maschinelle Klassifizierung erheblich.

Diebstahl von KI-Modellen (Model Extraction)

Durch wiederholte, systematische Abfragen an die Schnittstelle (API) eines KI-Modells kann ein Angreifer dessen internes Verhalten rekonstruieren. Dies ermöglicht es, ein funktional äquivalentes Modell zu stehlen, was den Verlust von geistigem Eigentum oder von hohen Trainingsinvestitionen bedeutet.

Offenlegung von Trainingsdaten (Data Leakage / Model Inversion)

KI-Modelle können sich an spezifische, oft seltene Beispiele aus ihren Trainingsdaten erinnern (Overfitting). Bei bestimmten Eingaben besteht die Gefahr, dass Modelle diese sensiblen Informationen, beispielsweise personenbezogene Daten oder Geschäftsgeheimnisse, im produktiven Betrieb unbeabsichtigt preisgeben.

Unsichere Integration und Orchestrierung der ML-Pipeline

Die Werkzeugkette zur Erstellung und Bereitstellung von KI (MLOps-Pipeline) stellt ein eigenständiges Angriffsziel dar. Eine Kompromittierung des Quellcode-Repositorys, der Trainingsumgebung oder des Artefakt-Speichers für Modelle kann zur Manipulation des gesamten KI-Systems führen.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins APP.4.10 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Fachverantwortliche, Informationssicherheitsbeauftragter (ISB), Entwickler

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

APP.4.10.A1 Planung des sicheren Einsatzes von KI (B) [ISB]

Es MUSS eine Richtlinie existieren, die die Ziele, Verantwortlichkeiten und grundlegenden Sicherheitsregeln für die Entwicklung, die Beschaffung und den Betrieb von KI-Systemen in der Institution festlegt.

APP.4.10.A2 Inventarisierung und Klassifizierung von Trainingsdaten (B) [Fachverantwortliche]

Alle für das Training von KI-Modellen verwendeten Datensätze MÜSSEN inventarisiert und entsprechend ihrer Schutzbedürftigkeit klassifiziert werden. Der Zugriff auf diese Daten MUSS restriktiv geregelt sein.

APP.4.10.A3 Grundlegende Absicherung der Modell-Schnittstellen (B)

Der Zugriff auf KI-Modelle, die über APIs bereitgestellt werden, MUSS authentifiziert und autorisiert werden. Die Schnittstellen MÜSSEN gegen gängige Web- und API-Angriffe geschützt werden.

APP.4.10.A4 Protokollierung von Trainingsläufen und API-Anfragen (B)

Trainingsläufe MÜSSEN protokolliert werden, um nachvollziehen zu können, welches Modell mit welchen Daten und Parametern trainiert wurde. Sicherheitsrelevante Anfragen an die produktiven Modell-APIs MÜSSEN ebenfalls protokolliert werden.

APP.4.10.A5 Nutzung vertrauenswürdiger Modellquellen (B)

Es DÜRFEN NICHT ungeprüfte externe KI-Modelle oder untrainierte Gewichte aus unzuverlässigen Quellen in produktive Systeme übernommen werden. Die Herkunft externer Modelle MUSS vor der Integration verifiziert werden.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

APP.4.10.A6 Sicherstellung der Integrität von Trainingsdaten (S)

Es SOLLTEN technische und organisatorische Maßnahmen ergriffen werden, um die Integrität der Trainingsdaten zu schützen. Dies umfasst die Überprüfung der Datenquellen, die Nutzung kryptografischer Prüfsummen sowie die Absicherung der Datenspeicher gegen unautorisierte

Veränderungen.

APP.4.10.A7 Absicherung der ML-Pipeline (S)

Der gesamte Lebenszyklus eines Modells SOLLTE durch eine abgesicherte MLOps-Pipeline verwaltet werden. Dies umfasst die Härtung von Code-Repositories, isolierte Trainingsumgebungen und geschützte Artefakt-Speicher.

APP.4.10.A8 Implementierung von Abwehrmaßnahmen gegen Adversarial Attacks (S) [Entwickler]

Es SOLLTEN robuste Programmierpraktiken und Techniken zur Validierung sowie Bereinigung von Eingabedaten eingesetzt werden, um die Wirksamkeit einfacher Adversarial Attacks (Umgehungsangriffe) einzudämmen.

APP.4.10.A9 Versionierung und Herkunftsverfolgung von Daten und Modellen (S)

Es SOLLTE ein System zur Versionierung von Datensätzen und Modellen etabliert werden. Es SOLLTE jederzeit nachvollziehbar sein, welche exakte Version eines Modells mit welcher Datenversion trainiert wurde (Data and Model Provenance).

APP.4.10.A10 Überwachung des Modellverhaltens im produktiven Betrieb (S)

Die Vorhersagen und Entscheidungen des KI-Modells im produktiven Betrieb SOLLTEN kontinuierlich überwacht werden, um Abweichungen vom erwarteten Verhalten (Model Drift) oder Anomalien, die auf Angriffe hindeuten, frühzeitig zu erkennen.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

APP.4.10.A11 Schutzmaßnahmen gegen Modell-Extraktion (H)

Der Zugriff auf die Modell-API SOLLTE automatisiert analysiert werden, um verdächtige Abfragemuster zu erkennen, die auf einen Extraktionsangriff hindeuten. Maßnahmen wie dynamisches Rate-Limiting oder das Hinzufügen von Wasserzeichen zu den Modellausgaben SOLLTEN implementiert werden. (C, I)

APP.4.10.A12 Durchführung von Adversarial-Robustness-Tests (H) [Entwickler]

KI-Modelle SOLLTEN proaktiv mit spezialisierten Frameworks auf ihre Widerstandsfähigkeit gegen Adversarial Attacks getestet werden. Die Ergebnisse SOLLTEN genutzt werden, um die Modelle durch robuste Trainingstechniken (z. B. Adversarial Training) zu härten. (I, A)

APP.4.10.A13 Einsatz von Techniken zur Erklärbarkeit und Interpretierbarkeit (XAI) (H)

Es SOLLTEN Techniken aus dem Bereich der Explainable AI (XAI) eingesetzt werden, um die Entscheidungen des Modells nachvollziehbar zu machen. (I)

APP.4.10.A14 Nutzung von Privacy-Enhancing Technologies (PETs) (H)

Beim Training mit sensiblen, insbesondere personenbezogenen Daten SOLLTEN kryptografische und statistische Verfahren (z. B. Differential Privacy, Federated Learning) eingesetzt werden, um das Risiko von Data Leakage und Model Inversion zu minimieren. (C)

4 Weiterführende Informationen

4.1 Wissenswertes

Das BSI stellt mit dem Katalog „Artificial Intelligence Cloud Computing Compliance Criteria Catalogue (AIC4)“ grundlegende Kriterien für den sicheren Einsatz von KI-Diensten in Cloud-Umgebungen bereit.

Für die technische Bewertung und Modellierung von Angriffen auf KI-Systeme ist das Framework „MITRE ATLAS“ (Adversarial Threat Landscape for AI Systems) eine etablierte Referenz.

Zusätzliche praxisnahe Hilfestellungen zur Absicherung von maschinellem Lernen bieten die Listen des OWASP-Projekts, insbesondere die „OWASP Machine Learning Security Top 10“ sowie die „OWASP Top 10 for LLM Applications“.

Kreuzreferenztabelle zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein APP.4.10 von Bedeutung:

- G 0.14 Ausspähen von Informationen (Spionage)
- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.20 Informationen oder Produkte aus unzuverlässiger Quelle
- G 0.21 Manipulation von Hard- oder Software
- G 0.22 Manipulation von Informationen
- G 0.23 Unbefugtes Eindringen in IT-Systeme
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.38 Missbrauch personenbezogener Daten
- G 0.46 Integritätsverlust schützenswerter Informationen

Anforderung	G 0.14	G 0.18	G 0.19	G 0.20	G 0.21	G 0.22	G 0.23	G 0.28	G 0.38	G 0.46
APP. 4.10. A1 (B)		X								
APP. 4.10. A2 (B)	X		X						X	
APP. 4.10. A3 (B)	X		X		X		X	X		
APP. 4.10. A4 (B)					X	X	X			
APP. 4.10. A5 (B)				X	X	X		X		X
APP. 4.10. A6 (S)				X		X				X
APP. 4.10. A7 (S)					X		X	X		X
APP. 4.10. A8 (S)						X				X

APP. 4.10. A9 (S)		X		X		X				X
APP. 4.10. A10 (S)					X	X				X
APP. 4.10. A11 (H)	X		X							
APP. 4.10. A12 (H)						X		X		X
APP. 4.10. A13 (H)						X				X
APP. 4.10. A14 (H)			X						X	